

BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC VĂN HIẾN
KHOA CÔNG NGHỆ - THÔNG TIN



TIỂU LUẬN KẾT THÚC HỌC PHẦN
BẢO MẬT IoT

Tấn công từ chối dịch vụ trong mạng IoT và giảm thiểu

Giảng viên hướng dẫn: Hồ Nhật Minh

Lớp học phần: 253INT441001

Mã học phần : INT4410

Sinh viên thực hiện: Trịnh Minh Hoàng Bảo

Mã số sinh viên: 231A010432

TP. HỒ CHÍ MINH – 2026

BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC VĂN HIẾN
KHOA CÔNG NGHỆ - THÔNG TIN



TIỂU LUẬN KẾT THÚC HỌC PHẦN
BẢO MẬT IoT

Tấn công từ chối dịch vụ trong mạng IoT và giảm thiểu

Giảng viên hướng dẫn: Hồ Nhật Minh

Lớp học phần: 253INT441001

Mã học phần : INT4410

Sinh viên thực hiện: Trịnh Minh Hoàng Bảo

Mã số sinh viên: 231A010432

TP. HỒ CHÍ MINH – 2026

THÔNG TIN VÀ CAM KẾT NỘP BÀI

Tên đề tài	Tấn công từ chối dịch vụ trong mạng IoT và giảm thiểu
Mã đề tài	25
Sinh viên/ Nhóm	Trịnh Minh Hoàng Bảo – 231A010432
Repo GitHub	https://github.com/SSAbys/Nhom25-iot-dos-migation
Bản báo cáo	231A010432_TrinhMinhHoangBao_DeTai25_TieuLuan_CuoiKy.pdf
Sản phẩm chính	Code Python Flask API Gateway và Script Flood Test, tệp cấu hình hệ thống, dữ liệu payload mẫu, log kiểm thử, sơ đồ kiến trúc hệ thống phòng thủ.
Ngày nộp	31/07/2026

Cam kết an toàn và học thuật

Tôi/chúng tôi cam kết toàn bộ thử nghiệm được thực hiện trong môi trường cục bộ, thiết bị thuộc quyền sở hữu hoặc dữ liệu giả lập/được phép; không quét, khai thác hay thu thập dữ liệu từ hệ thống thật. Báo cáo, mã nguồn và minh chứng là kết quả làm việc của cá nhân/nhóm; mọi nội dung kế thừa đều được trích dẫn rõ ràng. Repo không chứa secret, token, mật khẩu hoặc dữ liệu cá nhân thật.

Báo cáo có sử dụng công cụ AI hỗ trợ kiểm tra ngôn ngữ và chỉnh sửa câu văn, hình ảnh. Sinh viên chịu trách nhiệm hoàn toàn về nội dung, kết quả thực hiện và các kết luận trong báo cáo.

Em xin minh bạch tuyên bố rằng, trong quá trình thực hiện đồ án này, em có sử dụng công cụ AI ([Tên công cụ, ví dụ: Google Gemini / Notebook Gemini]) để hỗ trợ cho các công việc: [dịch thuật tài liệu, hỗ trợ viết các đoạn mã lệnh cơ bản và gợi ý cấu trúc dàn ý]. Các công cụ này chỉ đóng vai trò hỗ trợ; toàn bộ ý tưởng cốt lõi, phương pháp nghiên cứu, quá trình phân tích dữ liệu và kết luận của công trình đều do em tự thực hiện và hoàn toàn chịu trách nhiệm về tính nguyên bản, tính chính xác học thuật.

TP.Hồ Chí Minh, ngày 31 tháng 07 năm 2026

Sinh viên thực hiện



Trịnh Minh Hoàng Bảo

NHẬN XÉT CỦA GIẢNG VIÊN

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

TP.Hồ Chí Minh, ngày 31 tháng 07 năm 2026

Giảng viên bộ môn

MỤC LỤC

THÔNG TIN VÀ CAM KẾT NỘP BÀI.....	ii
CHƯƠNG 1. TỔNG QUAN ĐỀ TÀI.....	1
1.1. Bối cảnh và lý do chọn đề tài.....	1
1.2. Phát biểu vấn đề bảo mật	1
1.3. Mục tiêu của đề tài.....	2
1.4. Đối tượng, phạm vi và giới hạn an toàn.....	2
1.4.1. Đối tượng nghiên cứu (Thiết bị, giao thức, hệ thống và dữ liệu)	2
1.4.2. Phạm vi kỹ thuật	2
1.4.3. Thời gian và Giới hạn pháp lý	2
1.5. Sản phẩm và kết quả dự kiến	3
1.5.1. Danh mục sản phẩm kỹ thuật và sản phẩm phân tích	3
1.5.2. Khả năng tái sử dụng và giá trị chính	3
1.6. Cấu trúc báo cáo.....	4
Bảng đối chiếu mục tiêu và đầu ra	4
CHƯƠNG 2. CƠ SỞ LÝ THUYẾT VÀ TÀI LIỆU LIÊN QUAN	5
2.1. Kiến trúc hoặc bối cảnh kỹ thuật của hệ thống.....	5
2.1.1. Kiến trúc phân tầng IoT (Tập trung lớp Middleware/Gateway).....	5
2.1.2. Giao thức truyền thông và Định dạng dữ liệu.....	5
2.1.3. Cơ chế giới hạn tần suất (Rate Limiting).....	5
2.1.4. Công nghệ triển khai (Flask Micro-framework).....	5
2.1.5. Tiêu chuẩn kiểm định (OWASP ISVS & ISTG)	6
2.2. Khái niệm bảo mật trực tiếp liên quan	6
2.2.1. Các khái niệm cốt lõi (Chuỗi nhân quả bảo mật).....	6
2.2.2. Mô hình hóa mối đe dọa (Threat Modeling).....	7
2.2.3. Mật mã học và Cơ chế an toàn (Cryptography & Security Mechanisms)	7
2.2.4. Các nguyên tắc thiết kế an toàn (Secure by Design)	8
2.3. Trọng tâm theo hướng.....	8
2.4. Chuẩn, công cụ và nguồn GitHub chính.....	9
2.5. Công trình hoặc giải pháp liên quan	10
2.5.1. So sánh các giải pháp liên quan	10
2.5.2. Điểm đề án kế thừa và cải tiến.....	10

2.6. Tiêu kết Chương 2	11
CHƯƠNG 3. PHƯƠNG PHÁP VÀ THIẾT KẾ	12
3.1. Phương pháp thực hiện	12
3.2. Mô hình/kiến trúc đề xuất	13
3.3. Môi trường, công cụ và dữ liệu.....	14
3.4. Quy trình triển khai/đánh giá	15
3.5. Tiêu chí đánh giá.....	16
CHƯƠNG 4. TRIỂN KHAI VÀ KẾT QUẢ.....	17
4.1. Chuẩn bị môi trường	17
4.2. Thành phần sản phẩm	17
4.3. Kịch bản thử nghiệm/áp dụng.....	18
4.4. Kết quả.....	19
4.5. Script sinh báo cáo	20
4.6. Thảo luận và hạn chế	21
4.6.1. Đối chiếu kết quả với mục tiêu	21
4.6.2. Hạn chế	21
CHƯƠNG 5. ĐÁNH GIÁ BẢO MẬT.....	22
5.1. Tài sản và dữ liệu	22
5.2. Mối đe dọa và lỗ hổng	22
5.3. Ma trận rủi ro	23
5.4. Biện pháp giảm thiểu	24
5.5. Rủi ro còn lại.....	24
CHƯƠNG 6. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN.....	25
6.1. Kết luận.....	25
6.2. Hạn chế	25
6.3. Hướng phát triển.....	25
TÀI LIỆU THAM KHẢO.....	26
PHỤ LỤC A. CẤU TRÚC REPO VÀ GÓI NỘP.....	27
PHỤ LỤC B. NHẬT KÝ ĐÓNG GÓP.....	28
PHỤ LỤC C. CHECKLIST TRƯỚC KHI NỘP.....	28
PHỤ LỤC D. PHIẾU TỰ ĐÁNH GIÁ THEO RUBRIC.....	29

DANH MỤC HÌNH – BẢNG

Hình 2.1. Kiến trúc tổng thể hệ thống IoT quy mô nhỏ	6
Hình 2.2. Quy trình quản lý rủi ro	8
Hình 3.1. Kiến trúc đề xuất của hệ thống IoT quy mô nhỏ	13
Hình 4.1. Kết quả lập danh mục tài sản của hệ thống IoT	17
Bảng 5.1. Tài sản và dữ liệu cần bảo vệ	22
Bảng 5.2. Mối đe dọa và lỗ hổng	23
Bảng 5.3. Ma trận rủi ro.....	23

DANH MỤC TỪ VIẾT TẮT

Từ viết tắt	Nghĩa đầy đủ / Giải thích
CIA	Confidentiality, Integrity, Availability – Tính bí mật, tính toàn vẹn, tính sẵn sàng
CSF	Cybersecurity Framework – Khung an toàn thông tin (NIST)
HTTP/HTTPS	HyperText Transfer Protocol (Secure) – Giao thức truyền tải siêu văn bản (có bảo mật)
IDS/IPS	Intrusion Detection/Prevention System – Hệ thống phát hiện/ngăn chặn xâm nhập
IoT	Internet of Things – Internet vạn vật
ISTG	IoT Security Testing Guide – Hướng dẫn kiểm thử bảo mật IoT (OWASP)
ISVS	IoT Security Verification Standard – Chuẩn xác minh bảo mật IoT (OWASP)
MQTT	Message Queuing Telemetry Transport – Giao thức truyền dữ liệu IoT dạng publish/subscribe
NIST	National Institute of Standards and Technology – Viện Tiêu chuẩn và Công nghệ Quốc gia Hoa Kỳ
OWASP	Open Web Application Security Project – Dự án an toàn ứng dụng web mở
SIEM	Security Information and Event Management – Hệ thống quản lý thông tin và sự kiện an toàn
SP 800-30	Special Publication 800-30 – Tài liệu hướng dẫn đánh giá rủi ro của NIST

CHƯƠNG 1. TỔNG QUAN ĐỀ TÀI

1.1. Bối cảnh và lý do chọn đề tài

Sự bùng nổ của mạng lưới Internet vạn vật (IoT) đang tái định hình hạ tầng công nghệ toàn cầu, tạo nên các hệ sinh thái phức tạp kết nối giữa thiết bị phần cứng, phần mềm nhúng và các ứng dụng điện toán đám mây. Từ các hệ thống nhà thông minh đến mạng lưới cảm biến công nghiệp và thiết bị y tế, IoT mang lại sự tiện lợi vượt trội nhưng cũng mở rộng bề mặt tấn công cho các mối đe dọa mạng tinh vi.

Đặc trưng cốt lõi của phần lớn thiết bị đầu cuối trong hệ sinh thái này là giới hạn nghiêm ngặt về tài nguyên phần cứng, bao gồm dung lượng RAM nhỏ, năng lực xử lý của CPU hạn chế, băng thông hẹp và thường xuyên hoạt động bằng nguồn pin. Những hạn chế này khiến việc triển khai các cơ chế bảo mật phức tạp trực tiếp trên thiết bị trở nên khó khăn, biến chúng thành "mắt xích yếu nhất" trong hạ tầng an ninh mạng.

Xuất phát từ thực trạng cấu hình yếu, các thiết bị IoT đã trở thành mục tiêu lý tưởng cho các cuộc tấn công Từ chối dịch vụ (DoS/DDoS). Khi đối mặt với dòng lưu lượng rác liên tục, các thiết bị hoặc các nút trung chuyển (API Gateway) sẽ nhanh chóng rơi vào trạng thái cạn kiệt tài nguyên, dẫn đến treo hệ thống, sụt giảm tuổi thọ pin hoặc mất kết nối hoàn toàn. Điều này ảnh hưởng trực tiếp đến tính sẵn sàng (Availability) – một trong những yêu cầu bảo mật quan trọng hàng đầu trong các tiêu chuẩn kiểm định an ninh IoT hiện nay.

Việc đảm bảo an ninh cho IoT không chỉ dừng lại ở kiểm tra thiết bị mà cần một phương pháp luận toàn diện để đánh giá khả năng chống chịu của toàn bộ hệ thống. Trong đó, việc nghiên cứu các giải pháp phòng thủ chủ động như phân tầng lưu lượng và giới hạn tần suất (Rate Limiting) ngay tại lớp Gateway là vô cùng cấp thiết để bảo vệ các thiết bị yếu thế phía sau.

Đề tài "Tấn công từ chối dịch vụ trong mạng IoT và giảm thiểu" được lựa chọn nhằm:

- Phân tích sâu các lỗ hổng bảo mật dựa trên các mô hình tấn công thực tế.
- Đề xuất các biện pháp giảm thiểu tối ưu nhằm duy trì tính sẵn sàng của dữ liệu cảm biến – yếu tố sống còn của giám sát thời gian thực.

Cung cấp cái nhìn thực tế về việc áp dụng các tiêu chuẩn an ninh như OWASP ISVS và ISTG để bảo vệ hạ tầng IoT trước nguy cơ cạn kiệt tài nguyên.

1.2. Phát biểu vấn đề bảo mật

Hệ thống IoT quy mô nhỏ gồm nhiều tài sản quan trọng như thiết bị IoT, dữ liệu cảm biến, firmware, tài khoản quản trị và hạ tầng mạng. Do hạn chế về chi phí và khả năng quản trị, các hệ thống này thường tồn tại nhiều lỗ hổng như mật khẩu yếu, firmware chưa cập nhật, thiếu cơ chế mã hóa và xác thực, làm gia tăng nguy cơ truy cập trái phép, rò rỉ dữ liệu và tấn công mạng.

Nếu không được đánh giá và kiểm soát kịp thời, các rủi ro này sẽ ảnh hưởng đến tính bí mật, tính toàn vẹn và tính sẵn sàng của hệ thống. Vì vậy, đề tài tập trung xây dựng mô hình quản lý rủi ro

bảo mật cho hệ thống IoT quy mô nhỏ thông qua việc nhận diện tài sản, xác định mối đe dọa, xây dựng Risk Register, đánh giá rủi ro bằng ma trận 5×5 và đề xuất các biện pháp giảm thiểu phù hợp.

1.3. Mục tiêu của đề tài

Đề tài được thực hiện nhằm đạt được các mục tiêu sau:

- MT-01: Xác định và phân loại các tài sản quan trọng trong hệ thống IoT quy mô nhỏ.
- MT-02: Phân tích các mối đe dọa, lỗ hổng và đánh giá mức độ rủi ro đối với từng tài sản.
- MT-03: Xây dựng Risk Register và ma trận đánh giá rủi ro 5×5.
- MT-04: Đề xuất các biện pháp xử lý và giảm thiểu rủi ro có mức độ cao.
- MT-05: Xây dựng checklist kiểm tra bảo mật định kỳ cho hệ thống IoT.

1.4. Đối tượng, phạm vi và giới hạn an toàn

1.4.1. Đối tượng nghiên cứu (Thiết bị, giao thức, hệ thống và dữ liệu)

- Hệ thống và Giao thức: Đề tài tập trung nghiên cứu hệ thống Telemetry API (giao diện lập trình ứng dụng thu thập dữ liệu từ xa) vận hành trên giao thức truyền tải HTTP/HTTPS. Đây là thành phần cốt lõi trong việc kết nối giữa thiết bị đầu cuối và hạ tầng điều khiển theo mô hình hệ sinh thái IoT của OWASP ISVS.
- Dữ liệu: Đối tượng dữ liệu thực nghiệm là các gói tin có cấu trúc JSON – định dạng phổ biến được hỗ trợ trong các tiêu chuẩn truyền tin IoT. Các gói tin này giả lập thông số môi trường thực tế như nhiệt độ và độ ẩm, phục vụ cho việc kiểm thử các dịch vụ trao đổi dữ liệu (ISTG-DES).

1.4.2. Phạm vi kỹ thuật

- Giải pháp phòng thủ: Đề tài tập trung thiết kế và cấu hình cơ chế bảo mật chủ động tại tầng API Gateway bằng ngôn ngữ Python, sử dụng micro framework Flask.
- Kỹ thuật trọng tâm: Triển khai kỹ thuật kiểm soát lưu lượng Rate Limiting dựa trên bộ lọc IP định danh để phân loại và ngăn chặn các luồng dữ liệu bất thường.
- Đánh giá hiệu năng: Việc đánh giá tài nguyên hệ thống được thực hiện thông qua việc đo lường các thông số tải mô phỏng (CPU, RAM) của tiến trình xử lý backend khi đối mặt với các kịch bản lưu lượng khác nhau, tuân theo phương pháp luận kiểm thử của ISTG.

1.4.3. Thời gian và Giới hạn pháp lý

- Nguyên tắc an toàn: Đề tài cam kết thực hiện nghiêm túc các nguyên tắc đạo đức và an toàn thông tin. Nghiên cứu tuyệt đối không viết, không phát tán và không sử dụng các công cụ tấn công thực tế có khả năng gây hại đến hạ tầng mạng công cộng.

- Môi trường thực nghiệm: Toàn bộ quá trình mô phỏng gửi yêu cầu vượt ngưỡng (Flood request) được giới hạn thực hiện trong môi trường phòng Lab nội bộ (Localhost / Lab Network). Hệ thống thử nghiệm được thiết lập hoàn toàn tách biệt khỏi mạng Internet công cộng, đảm bảo tính kiểm soát và an toàn tuyệt đối cho các thiết bị xung quanh trong suốt thời gian thực hiện đồ án.

1.5. Sản phẩm và kết quả dự kiến

1.5.1. Danh mục sản phẩm kỹ thuật và sản phẩm phân tích

Sản phẩm kỹ thuật:

- Mã nguồn chương trình Flask API Gateway: Một hệ thống Gateway hoàn chỉnh được xây dựng trên micro framework Flask, tích hợp sẵn cơ chế phòng thủ Rate Limiting để bảo vệ các điểm cuối (endpoints) thu thập dữ liệu.
- 02 Script Python mô phỏng: Bao gồm kịch bản gửi dữ liệu thông thường (Normal) và kịch bản tấn công vượt ngưỡng (Over-limit) để kiểm thử khả năng chịu tải của hệ thống.
- Tài liệu hướng dẫn (README.md): File hướng dẫn chi tiết cách triển khai, cấu hình và vận hành hệ thống trong môi trường Lab.

Sản phẩm phân tích:

- Nhật ký hệ thống (System Logs): Minh chứng thực nghiệm ghi lại sự chuyển đổi trạng thái phản hồi của API từ HTTP 200 OK (hợp lệ) sang HTTP 429 Too Many Requests (khi bị chặn do quá tải).
- Bảng đánh giá tác động DoS: Phân tích chi tiết mức độ ảnh hưởng của tấn công lên các tầng tài nguyên phần cứng IoT, tập trung vào bộ vi xử lý (ISTG-PROC) và bộ nhớ (ISTG-MEM).
- Checklist phòng chống DoS nâng cao: Danh mục các biện pháp giảm thiểu rủi ro tại tầng Gateway và API, được xây dựng dựa trên khung kiểm thử của ISTG và các yêu cầu bảo mật của OWASP ISVS.

1.5.2. Khả năng tái sử dụng và giá trị chính

- Giá trị tham khảo: Mã nguồn và mô hình cấu hình của đồ án cung cấp một tài liệu tham khảo nền tảng cho các dự án phát triển phần mềm nhúng hoặc các hệ thống Gateway thu thập dữ liệu IoT quy mô vừa và nhỏ.
- Tích hợp an toàn từ đầu: Sản phẩm giúp các nhà phát triển dễ dàng tích hợp các tính năng an toàn thông tin cơ bản ngay từ giai đoạn thiết kế (Security by Design), đáp ứng các tiêu chuẩn xác thực an ninh quốc tế như OWASP ISVS.
- Bảo vệ tính sẵn sàng: Thông qua việc áp dụng Rate Limiting, đồ án chứng minh giải pháp hiệu quả trong việc duy trì tính sẵn sàng (Availability) của các dịch vụ trao đổi dữ liệu (ISTG-DES), ngăn chặn nguy cơ cạn kiệt tài nguyên trước các cuộc tấn công ngập lụt phổ biến trong mạng IoT.

1.6. Cấu trúc báo cáo

Báo cáo gồm sáu chương. Chương 1 trình bày tổng quan về đề tài, bối cảnh, mục tiêu và phạm vi nghiên cứu. Chương 2 giới thiệu cơ sở lý thuyết liên quan đến kiến trúc IoT, các chuẩn bảo mật OWASP ISVS, ISTG và cơ chế Rate Limiting. Chương 3 trình bày phương pháp thực hiện, mô hình hóa mối đe dọa theo khung STRIDE và phương pháp đánh giá rủi ro. Chương 4 mô tả quá trình triển khai xây dựng API Gateway, script mô phỏng và các sản phẩm phòng thủ. Chương 5 trình bày kết quả thực nghiệm, đánh giá bảo mật chi tiết, xây dựng Risk Register và bộ Checklist kiểm tra an ninh. Cuối cùng, Chương 6 trình bày kết luận, đánh giá hạn chế và hướng phát triển của đề tài.

Repo GitHub cá nhân của đề tài: <https://github.com/SSAbys/Nhom25-iot-dos-migration> (toàn bộ báo cáo, sơ đồ, Risk Register, ma trận rủi ro và checklist được lưu trong repo này).

Bảng đối chiếu mục tiêu và đầu ra

Mã mục tiêu	Nội dung mục tiêu	Đầu ra tương ứng	Cách kiểm chứng
MT-01	Xác định và phân loại các tài sản quan trọng trong hệ thống IoT quy mô nhỏ.	Danh mục tài sản hệ thống (Asset Inventory).	Đối chiếu danh mục với luồng dữ liệu thực tế và ranh giới tin cậy.
MT-02	Phân tích các mối đe dọa, lỗ hổng và đánh giá mức độ rủi ro đối với từng tài sản.	Bảng phân tích mối đe dọa theo khung STRIDE.	Kiểm tra tính logic của chuỗi nhân quả bảo mật và điểm số DREAD.
MT-03	Xây dựng Risk Register và ma trận đánh giá rủi ro 5×5.	Bảng Risk Register và Ma trận rủi ro trực quan.	Xác thực mức độ ưu tiên dựa trên tích số của Khả năng và Tác động.
MT-04	Đề xuất các biện pháp xử lý và giảm thiểu rủi ro có mức độ cao.	Kế hoạch kiểm soát và giảm thiểu (Mitigation Plan).	Đánh giá rủi ro còn lại (Residual Risk) sau khi áp dụng các biện pháp kiểm soát.
MT-05	Xây dựng checklist kiểm tra bảo mật định kỳ cho hệ thống IoT.	Bộ Checklist an ninh tiêu chuẩn dựa trên OWASP ISVS/ISTG.	Đối soát với các yêu cầu bảo mật của ETSI EN 303 645 hoặc NISTIR 8259.

CHƯƠNG 2. CƠ SỞ LÝ THUYẾT VÀ TÀI LIỆU LIÊN QUAN

2.1. Kiến trúc hoặc bối cảnh kỹ thuật của hệ thống

2.1.1. Kiến trúc phân tầng IoT (Tập trung lớp Middleware/Gateway)

Trong mô hình kiến trúc IoT tiêu chuẩn, lớp Trung gian (Middleware) hay Gateway đóng vai trò là nút trung chuyển cốt lõi giữa lớp Cảm nhận (Perception) và lớp Ứng dụng (Application).

- Vai trò chiến lược: Gateway là điểm hội tụ luồng dữ liệu từ các thiết bị đầu cuối có tài nguyên hạn chế trước khi đẩy lên đám mây.
- Bề mặt tấn công DoS: Vì phải mở công khai các endpoint để tiếp nhận dữ liệu telemetry, lớp này trở thành "điểm nghẽn" lý tưởng để kẻ tấn công khai thác cạn kiệt tài nguyên xử lý (CPU, RAM) thông qua các kỹ thuật ngập lụt (Flooding).

2.1.2. Giao thức truyền thông và Định dạng dữ liệu

Đề tài tập trung vào các công nghệ phổ biến nhất trong hệ sinh thái API của IoT:

- HTTP/HTTPS (RESTful API): Sử dụng mô hình yêu cầu/đáp ứng (Request/Response) để truyền tải dữ liệu telemetry từ thiết bị tới Gateway. Việc sử dụng HTTPS đảm bảo tính bảo mật kênh truyền nhưng cũng tiêu tốn tài nguyên xử lý hơn khi phải bắt tay (handshake) dưới cường độ request lớn.
- JSON (JavaScript Object Notation): Đây là định dạng dữ liệu nhẹ, tối ưu cho các gói tin telemetry chứa thông số cảm biến (như nhiệt độ, độ ẩm) do cấu trúc đơn giản và dễ phân tích (parse) trên cả thiết bị nhúng và server.

2.1.3. Cơ chế giới hạn tần suất (Rate Limiting)

Đây là kỹ thuật phòng thủ chủ động tại tầng ứng dụng (Layer 7) nhằm duy trì tính sẵn sàng (Availability) của hệ thống:

- Nguyên lý: Thiết lập ngưỡng giới hạn số lượng yêu cầu tối đa mà một địa chỉ IP hoặc Access Token được phép gửi trong một đơn vị thời gian.
- Xử lý quá tải: Khi lưu lượng vượt ngưỡng (vượt quá khả năng xử lý của backend), hệ thống sẽ chủ động ngắt kết nối và phản hồi mã lỗi HTTP 429 Too Many Requests, giúp bảo vệ CPU và RAM khỏi trạng thái treo hoặc cạn kiệt tài nguyên.

2.1.4. Công nghệ triển khai (Flask Micro-framework)

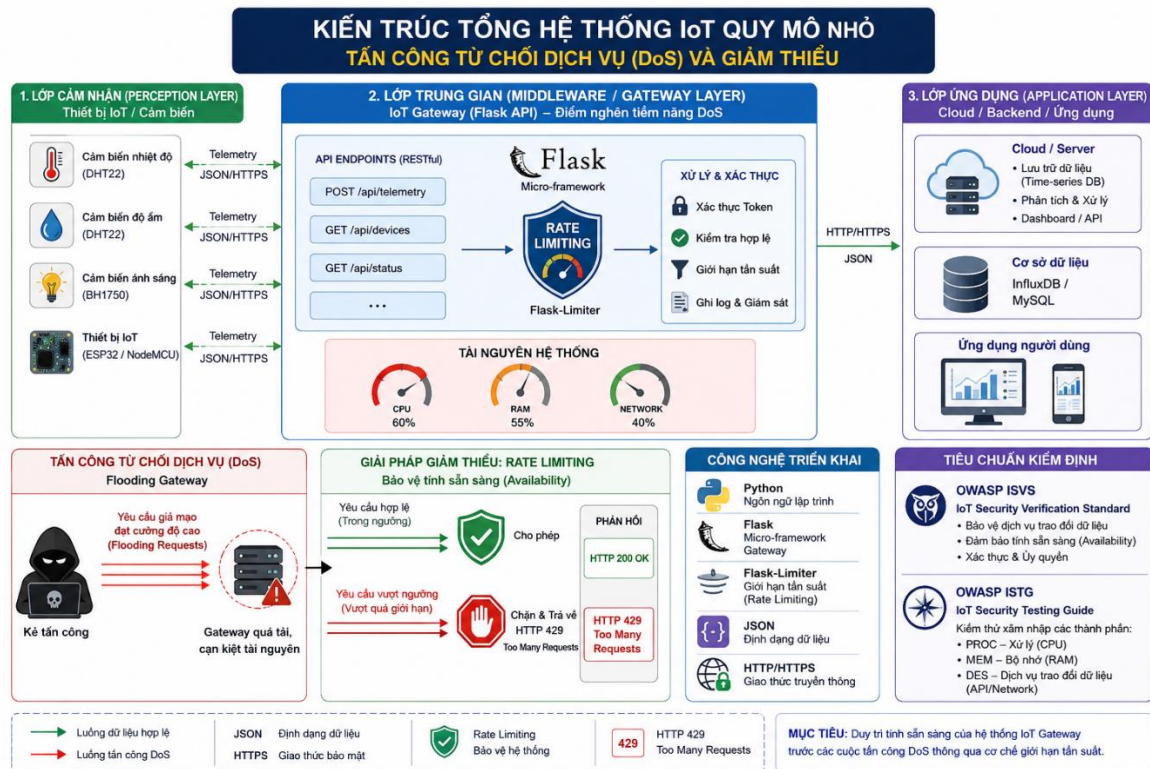
Flask được lựa chọn làm công cụ giả lập IoT Gateway nhờ các đặc trưng:

- Trọng lượng nhẹ (Lightweight): Không áp đặt các thư viện dư thừa, phù hợp để xây dựng các API endpoint chuyên biệt cho việc thu thập dữ liệu IoT.
- Khả năng mở rộng: Dễ dàng tích hợp các middleware về an ninh mạng (như Flask-Limiter) để triển khai cơ chế Rate Limiting một cách linh hoạt trên nền ngôn ngữ Python.

2.1.5. Tiêu chuẩn kiểm định (OWASP ISVS & ISTG)

Nghiên cứu dựa trên các khung lý thuyết bảo mật quốc tế để đảm bảo tính thực tiễn:

- OWASP ISVS: Cung cấp các tiêu chuẩn xác thực an ninh cho IoT, trong đó nhấn mạnh việc bảo vệ các dịch vụ trao đổi dữ liệu và duy trì tính sẵn sàng.
- OWASP ISTG: Cung cấp phương pháp luận kiểm thử xâm nhập chuyên sâu cho các thành phần tài nguyên (PROC - Xử lý, MEM - Bộ nhớ, DES - Dịch vụ trao đổi dữ liệu), làm cơ sở để đo lường tác động của tấn công DoS lên thiết bị.



Hình 2.1. Kiến trúc tổng thể hệ thống IoT quy mô nhỏ. Nguồn: tạo bằng ChatGPT (OpenAI); nhóm tác giả tự hiệu chỉnh nhãn, chú thích tiếng Việt và bố cục các lớp kiến trúc cho phù hợp với đề tài (2026).

2.2. Khái niệm bảo mật trực tiếp liên quan

2.2.1. Các khái niệm cốt lõi (Chuỗi nhân quả bảo mật)

Phân tích an toàn luôn bắt đầu bằng việc xác định mối liên kết giữa bốn yếu tố tạo thành một chuỗi nhân quả: Tài sản bị mối đe dọa nhắm tới thông qua lỗ hổng, dẫn đến một rủi ro cụ thể.

- Tài sản (Asset): Là những thứ có giá trị cần được bảo vệ. Tài sản bao gồm: dữ liệu telemetry (thông số cảm biến JSON), tính sẵn sàng của dịch vụ, và năng lực xử lý của thiết bị IoT/Gateway.
- Mối đe dọa (Threat): Một tác nhân hoặc sự kiện tiềm tàng có thể gây hại cho tài sản. Ví dụ: kẻ tấn công thực hiện ngập lụt (Flooding), mã độc botnet (như Mirai) hoặc các yêu cầu kết nối liên tục nhằm làm cạn kiệt tài nguyên.

- **Lỗ hổng (Vulnerability):** Là điểm yếu cụ thể của hệ thống mà mối đe dọa có thể khai thác. Trong bối cảnh này, lỗ hổng chính là việc các endpoint telemetry mở công khai nhưng thiếu cơ chế tự sàng lọc lưu lượng hoặc giới hạn request theo thời gian thực.
- **Rủi ro (Risk):** Là xác suất một mối đe dọa khai thác thành công lỗ hổng nhân với mức độ tác động của hậu quả. Công thức định tính thường dùng là: $Rủi\ ro = Khả\ năng\ (1-5) \times Tác\ động\ (1-5)$.
- **Kiểm soát (Control/Mitigation):** Các biện pháp kỹ thuật nhằm giảm thiểu rủi ro. Tập trung vào Rate Limiting (giới hạn tần suất) tại Gateway để bảo vệ tính sẵn sàng.

2.2.2. Mô hình hóa mối đe dọa (Threat Modeling)

Đây là quy trình có cấu trúc để nhận diện rủi ro ngay từ giai đoạn thiết kế. Khung STRIDE: Phân loại mối đe dọa thành 6 nhóm:

- **Spoofing (Giả mạo):** Mạo danh thiết bị IoT hợp lệ.
- **Tampering (Sửa đổi):** Thay đổi dữ liệu telemetry trên đường truyền.
- **Repudiation (Chối bỏ):** Phủ nhận hành động đã thực hiện.
- **Information Disclosure (Lộ tin):** Nghe lén dữ liệu nhạy cảm.
- **Denial of Service (Từ chối dịch vụ):** Làm nghẽn hoặc quá tải hệ thống – trọng tâm của đồ án.
- **Elevation of Privilege (Leo thang đặc quyền):** Chiếm quyền điều khiển cao hơn mức cho phép.

Mô hình DREAD: Dùng để chấm điểm rủi ro dựa trên 5 yếu tố: Thiệt hại (Damage), Khả năng tái lập (Reproducibility), Độ dễ khai thác (Exploitability), Số người ảnh hưởng (Affected users) và Độ dễ phát hiện (Discoverability).

2.2.3. Mật mã học và Cơ chế an toàn (Cryptography & Security Mechanisms)

Mật mã học cung cấp các công cụ toán học để bảo vệ thông tin.

- **Tính sẵn sàng (Availability):** Được duy trì thông qua giới hạn lưu lượng, dự phòng và thiết kế chịu lỗi.
- **Tính bí mật và Toàn vẹn:** Sử dụng mã hóa đối xứng (AES, ChaCha20) và các mã xác thực thông điệp (MAC/HMAC).
- **Mật mã hạng nhẹ (Lightweight Cryptography - LWC):** Thiết kế cho thiết bị IoT hạn chế tài nguyên (như thuật toán Ascon đã được NIST chuẩn hóa) để giảm độ trễ và tiêu thụ năng lượng.

Nonce và Timestamp: Được sử dụng trong các gói tin để chống lại tấn công phát lại (Replay Attack).

2.2.4. Các nguyên tắc thiết kế an toàn (Secure by Design)

Phòng thủ theo chiều sâu (Defense in Depth): Thiết lập nhiều lớp bảo vệ độc lập.

Mặc định an toàn (Fail-safe defaults): Khi có sự cố (như vượt ngưỡng request), hệ thống mặc định từ chối (trả về lỗi HTTP 429) thay vì cho phép xử lý tiếp gây treo hệ thống.

Đặc quyền tối thiểu (Least Privilege): Mỗi thiết bị/IP chỉ được cấp đúng quyền và hạn mức tài nguyên cần thiết.

Đề tài thuộc Hướng D – Tấn công, lỗ hổng và quyền riêng tư, vì vậy nội dung được vận dụng theo một quy trình phân tích kỹ thuật gồm các bước: xây dựng sơ đồ luồng dữ liệu (DFD) và cây tấn công (Attack tree), xác định điều kiện xảy ra và tác động đến quyền riêng tư, phân tích bảng STRIDE và rủi ro, đồng thời thiết lập cơ chế phòng thủ nhiều lớp (Hình 2.2). Quy trình này là khung tham chiếu xuyên suốt cho Chương 3 và Chương 5 của báo cáo.



Hình 2.2. Quy trình quản lý rủi ro. Nguồn: tạo bằng ChatGPT (OpenAI); nhóm tác giả tự hiệu chỉnh các bước và nhãn quy trình theo khung NIST SP 800-30 áp dụng trong đề tài (2026).

2.3. Trọng tâm theo hướng

Vì thuộc **hướng D** (Mô hình tấn công và giải pháp phòng thủ kỹ thuật), Chương 2 của đề tài tập trung vào ba nội dung trọng tâm: **mô hình hóa hệ thống và luồng dữ liệu (DFD)**, **phân tích kịch bản tấn công qua khung STRIDE/Cây tấn công**, và **đánh giá tác động kỹ thuật lên tài nguyên hệ thống**.

Mô hình hóa: Đề tài xây dựng Sơ đồ luồng dữ liệu (Hình 2.1) để nhận diện các thành phần từ tầng cảm biến (Perception) qua Gateway đến Đám mây, đồng thời xác lập các **ranh giới tin cậy (Trust Boundary)** tại các cổng dịch vụ mở như HTTP hoặc MQTT. Mỗi điểm giao tiếp trên sơ đồ được soi chiếu để xác định các bề mặt tấn công tiềm tàng có thể bị khai thác nhằm phá vỡ tính sẵn sàng của dịch vụ.

Phân tích kịch bản: Quy trình phân tích mối đe dọa được cụ thể hóa qua bảng **STRIDE** (Bảng 2.2), tập trung vào các nguy cơ **Từ chối dịch vụ (DoS)**, **Giả mạo (Spoofing)** và **Sửa đổi dữ liệu (Tampering)**. Các kịch bản tấn công như **TCP SYN Flood** hay **ICMP Reflected** được minh họa chi tiết qua **Cây tấn công (Attack Tree)** tại Hình 2.2, giúp làm rõ các điều kiện cần thiết và trình tự các bước kẻ tấn công thực hiện để xâm nhập hệ thống.

Tác động và phòng chống: Đề tài đo lường cụ thể hậu quả kỹ thuật của tấn công, như việc **tải CPU đạt ngưỡng 100%** hoặc thời gian mất liên lạc (TTCL) xảy ra tức thì, tại Bảng 2.3. Trên cơ sở đó, các giải pháp phòng thủ chủ động như **Rate Limiting** (giới hạn tần suất) tại Gateway và thiết lập quy tắc tường lửa (Firewall rules) được đề xuất để chặn đứng lưu lượng rác, bảo vệ tài nguyên xử lý và duy trì tính sẵn sàng cho toàn bộ mạng IoT [12, 1.5.3, 310, 501]. Các thông số tác động này được sử dụng làm chỉ số đối chiếu xuyên suốt trong phần đánh giá thực nghiệm tại Chương 5

2.4. Chuẩn, công cụ và nguồn GitHub chính

STT	Nguồn/repo	URL/phần bản	Phần đã sử dụng	Truy cập
1	OWASP ISVS	https://github.com/OWASP/IoT-Security-Verification-Standard-ISVS	Sử dụng làm khung tiêu chuẩn xác thực an ninh cho toàn bộ hệ sinh thái IoT, đặc biệt là các yêu cầu về tính sẵn sàng và truyền thông	17/07/2026
2	OWASP ISTG	https://github.com/OWASP/owasp-istg	Áp dụng phương pháp luận kiểm thử xâm nhập; sử dụng các danh mục kiểm tra tài nguyên hệ thống như ISTG-PROC (xử lý), ISTG-MEM (bộ nhớ) và ISTG-DES (dịch vụ trao đổi dữ liệu) để đo lường tác động DoS	17/07/2026
3	Flask (Pallets)	https://github.com/pallets/flask	Sử dụng micro-framework Flask để xây dựng mô hình giả lập API Gateway nhận dữ liệu telemetry	17/07/2026
4	OWASP IoT Top 10	https://owasp.org/www-project-internet-of-things/	Tham chiếu các nguy cơ bảo mật phổ biến (như mật khẩu yếu - cấu hình mặc định không an toàn) để xây dựng kịch bản tấn công và phòng thủ	17/07/2026

STT	Nguồn/repo	URL/phần bản	Phần đã sử dụng	Truy cập
5	ISO/IEC 27400:2022	(Tài liệu tiêu chuẩn)	Tham chiếu các nguyên tắc quốc tế về kiểm soát rủi ro, bảo mật và quyền riêng tư dành riêng cho giải pháp IoT	17/07/2026
6	ETSI EN 303 645	(Tài liệu tiêu chuẩn)	Áp dụng các nguyên tắc bảo mật cơ bản cho thiết bị tiêu dùng như không dùng mật khẩu mặc định và cập nhật phần mềm an toàn	17/07/2026

2.5. Công trình hoặc giải pháp liên quan

2.5.1. So sánh các giải pháp liên quan

Hiện nay, nghiên cứu về giảm thiểu DoS/DDoS trong IoT chia thành ba nhóm giải pháp chính:

- Giải pháp dựa trên Trí tuệ nhân tạo (ML/DL): Các nghiên cứu sử dụng mô hình học máy (như Random Forest, XGBoost) hoặc học sâu (CNN, LSTM) đạt độ chính xác rất cao, từ 97% đến trên 99%. Tuy nhiên, các giải pháp này đòi hỏi tài nguyên tính toán lớn (CPU, RAM) và thời gian huấn luyện dài, gây khó khăn khi triển khai trực tiếp trên các nút biên hoặc Gateway có cấu hình yếu.
- Giải pháp mạng điều khiển bằng phần mềm (SDN) và Entropy: Sử dụng bộ điều khiển SDN để phân tích tính hỗn loạn (Entropy) của lưu lượng nhằm phát hiện IP giả mạo. Giải pháp này hiệu quả trong việc bảo vệ hạ tầng mạng quy mô lớn nhưng lại biến bộ điều khiển SDN thành "điểm nghẽn" mới nếu bị tấn công ngập lụt bản tin Packet-In.
- Giải pháp lọc lưu lượng tại biên (MUD & eBPF): Sử dụng tiêu chuẩn MUD (Manufacturer Usage Description) kết hợp với eBPF/iptables để chặn lưu lượng ngay tại bộ định tuyến. Phương pháp này rất nhanh (line-rate filtering) nhưng phụ thuộc vào việc nhà sản xuất thiết bị phải cung cấp file cấu hình MUD chuẩn và yêu cầu hệ điều hành hỗ trợ eBPF.

2.5.2. Điểm đồ án kế thừa và cải tiến

Đồ án tập trung vào kỹ thuật Rate Limiting (Giới hạn tần suất) tại lớp API Gateway, kế thừa và cải tiến các điểm sau:

- Kế thừa:
 - Khung phương pháp luận: Đồ án kế thừa quy trình kiểm thử xâm nhập và đánh giá tài nguyên (PROC/MEM) từ tiêu chuẩn OWASP ISTG và các yêu cầu về tính sẵn sàng của OWASP ISVS.

- Tư duy phòng thủ theo chiều sâu: Tiếp thu nguyên tắc thiết kế an toàn (Secure by Design), đặt hàng rào bảo vệ ngay tại điểm tiếp nhận dữ liệu telemetry công khai.
- Điểm cải tiến/Khác biệt:
 - Tối ưu cho tài nguyên hạn chế: Thay vì sử dụng các mô hình ML/DL nặng nề, đề án sử dụng cơ chế Rate Limiting dựa trên IP/Token tích hợp vào micro-framework Flask. Đây là giải pháp trọng lượng nhẹ, không gây trễ lớn cho hệ thống và phù hợp với đặc thù phần cứng IoT.
 - Xử lý tại tầng ứng dụng (Layer 7): Khác với việc chặn lưu lượng thô ở tầng mạng (Layer 3/4) như eBPF hay SDN, giải pháp của đề án cho phép phân loại sâu hơn dòng dữ liệu telemetry (JSON), giúp phản hồi lỗi chuẩn hóa (HTTP 429) thay vì chỉ ngắt kết nối đột ngột, từ đó duy trì tính ổn định cho ứng dụng backend.
 - Tính linh hoạt và thực tiễn: Giải pháp có khả năng cấu hình ngưỡng (threshold) linh hoạt theo thời gian thực, cho phép nhà phát triển điều chỉnh hàng rào bảo vệ dựa trên hành vi thực tế của thiết bị mà không cần can thiệp vào hạ tầng mạng phức tạp.

2.6. Tiểu kết Chương 2

Chương 2 đã thiết lập toàn diện nền tảng lý thuyết và kiến trúc kỹ thuật cốt lõi cho đề án thuộc Hướng D. Nội dung tập trung phân tích lớp Gateway trong mô hình phân tầng IoT, bề mặt tấn công DoS và vai trò phòng thủ của Rate Limiting. Quy trình nghiên cứu vận dụng sơ đồ luồng dữ liệu (DFD), cây tấn công cùng khung mô hình hóa mối đe dọa STRIDE. Đồng thời, các chuẩn bảo mật quốc tế như OWASPISVS và ISTG được tích hợp làm khung tham chiếu xuyên suốt. Qua đó, chương tạo nền tảng vững chắc cho việc triển khai mô hình giả lập và đánh giá thực nghiệm tại các chương tiếp theo.

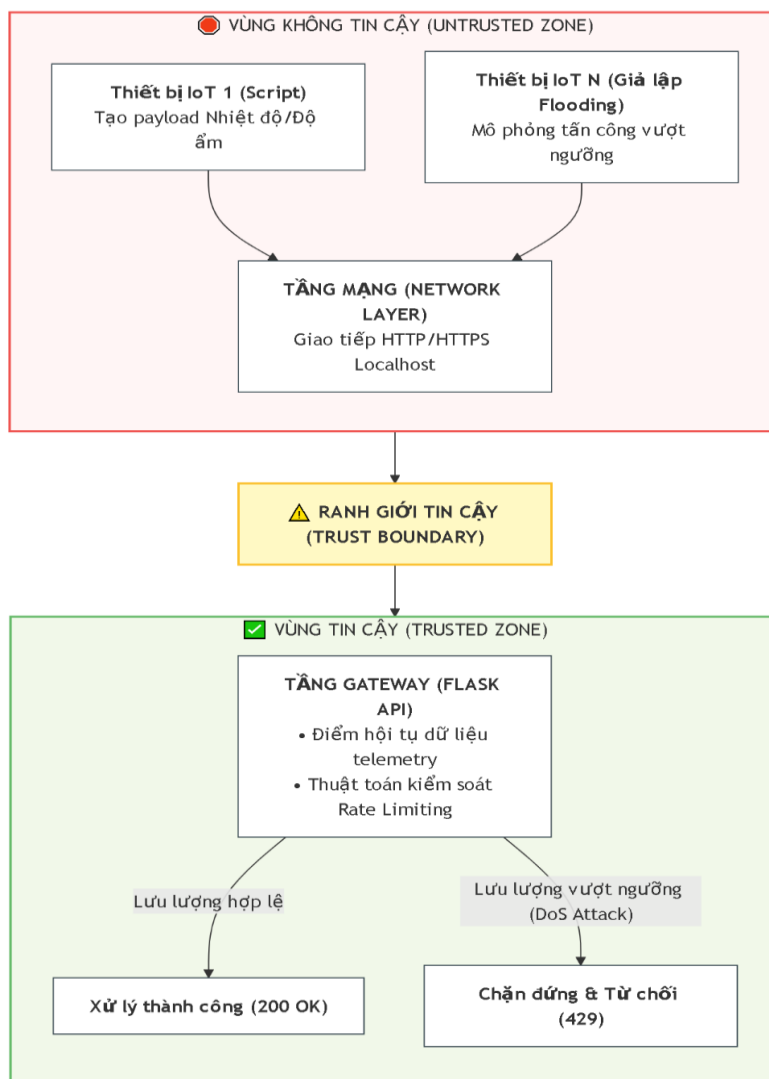
CHƯƠNG 3. PHƯƠNG PHÁP VÀ THIẾT KẾ

3.1. Phương pháp thực hiện

Quy trình nghiên cứu và triển khai đề tài được thực hiện tuần tự qua 5 bước chính:

1. **Khảo sát và nghiên cứu lý thuyết:** Nhóm tiến hành thu thập tài liệu và nghiên cứu các chuẩn bảo mật IoT quốc tế (như OWASP ISVS và ISTG) để hiểu rõ tác động của tấn công DoS lên tài nguyên phần cứng. Công cụ sử dụng bao gồm các tài liệu kỹ thuật chính thống và kho lưu trữ mã nguồn mở trên GitHub. Đầu ra của bước này là cơ sở lý thuyết tổng quan và hệ thống hóa mô hình lỗ hổng tài nguyên thiết bị biên.
2. **Thiết kế hệ thống và mô hình hóa mối đe dọa:** Tiến hành xây dựng sơ đồ luồng dữ liệu (DFD), xác định ranh giới tin cậy và phân tích chi tiết các kịch bản tấn công thông qua khung STRIDE cùng cây tấn công (Attack Tree). Quá trình này áp dụng các phương pháp luận quản lý rủi ro để nhận diện chính xác bề mặt tấn công. Sản phẩm thu được là sơ đồ kiến trúc hệ thống và bảng phân tích rủi ro (Risk Register).
3. **Dựng lab và phát triển mô hình giả lập:** Xây dựng ứng dụng API Gateway bằng ngôn ngữ Python trên nền tảng micro-framework Flask và tích hợp module Rate Limiting (Flask-Limiter) để kiểm soát lưu lượng. Công cụ chủ yếu gồm môi trường lập trình Python 3.10+, thư viện mã nguồn mở và các tệp cấu hình tĩnh. Sản phẩm đầu ra là mã nguồn hoàn chỉnh của hệ thống Gateway và các script mô phỏng thiết bị IoT gửi dữ liệu telemetry.
4. **Thực nghiệm và kiểm thử xâm nhập:** Thực hiện vận hành mô hình trong môi trường phòng lab nội bộ, chạy các kịch bản kiểm thử từ lưu lượng hợp lệ đến các đợt tấn công ngập lụt (HTTP Flood) dồn dập. Công cụ sử dụng là các script Python kiểm thử tự động kết hợp các lệnh dòng lệnh để gửi request vượt ngưỡng. Sản phẩm thu được là các tập tin nhật ký hệ thống (System logs) ghi nhận trạng thái phản hồi 200 OK và mã lỗi chuẩn 429 Too Many Requests.
5. **Đánh giá kết quả và xây dựng Checklist giảm thiểu:** Tiến hành phân tích dữ liệu log thực nghiệm, đối chiếu mức độ hoàn thành với các mục tiêu ban đầu và đánh giá rủi ro còn lại của hệ thống. Công cụ áp dụng là phương pháp so sánh định tính dựa trên bộ tiêu chuẩn kiểm định an ninh ISTG. Sản phẩm đầu ra gồm bảng đối chiếu kết quả, bộ Checklist giảm thiểu rủi ro bảo mật và tài liệu báo cáo hoàn chỉnh.

3.2. Mô hình/kiến trúc đề xuất



Hình 3.1. Kiến trúc đề xuất của hệ thống IoT quy mô nhỏ. Nguồn: tạo bằng ChatGPT (OpenAI); nhóm tác giả tự hiệu chỉnh thành phần và nhận kiến trúc cho khớp với mô hình đề xuất tại mục 3.2 (2026).

Mô hình kiến trúc đề xuất được thiết kế nhằm phân định rõ ràng các vùng an ninh để kiểm soát luồng dữ liệu tại lớp trung chuyển IoT. Vùng không tin cậy là nơi xuất phát của các thiết bị IoT gửi dữ liệu telemetry hoặc script giả lập tấn công ngập lụt. Mọi gói tin từ bên ngoài bắt buộc phải đi qua ranh giới tin cậy để tiến vào tầng Gateway tích hợp thuật toán Rate Limiting. Đối với lưu lượng hợp lệ nằm trong hạn mức, hệ thống xử lý và phản hồi thành công mã trạng thái 200 OK. Ngược lại, khi lưu lượng vượt ngưỡng do tấn công DoS, Gateway sẽ chủ động chặn đứng và trả về mã lỗi 429 Too Many Requests. Lựa chọn thiết kế tập trung phòng thủ tại tầng ứng dụng giúp tối ưu tài nguyên phần cứng, bảo vệ CPU và RAM, đồng thời duy trì tính sẵn sàng cho toàn bộ hệ thống.

3.3. Môi trường, công cụ và dữ liệu

Thành phần	Phiên bản	Mục đích	Ghi chú an toàn
Hệ điều hành	Windows 10/11 hoặc Linux (Ubuntu 20.04+)	Cung cấp môi trường nền tảng để vận hành máy chủ ứng dụng và script mô phỏng.	Áp dụng nguyên tắc phân quyền tối thiểu, chỉ vận hành trong không gian thử nghiệm nội bộ.
Ngôn ngữ Python	3.10+	Ngôn ngữ lập trình chính để xây dựng mã nguồn API Gateway và script kiểm thử.	Sử dụng các phiên bản ổn định, cập nhật các gói thư viện đi kèm để tránh lỗ hổng bảo mật mã nguồn.
Môi trường ảo (venv)	Built-in (Python)	Cô lập môi trường thực thi, quản lý các gói thư viện phụ thuộc riêng cho đề án.	Đảm bảo cách ly hoàn toàn các gói phụ thuộc, tránh xung đột và bảo vệ hệ thống chung của máy host.
Flask	3.1.x	Micro-framework xây dựng API Gateway trung chuyển và xử lý dữ liệu telemetry.	Cấu hình ứng dụng chỉ lắng nghe trên giao diện cục bộ (127.0.0.1), không mở public trực tiếp ra mạng ngoài.
Flask-Limiter	3.x	Thư viện chuyên dụng tích hợp cơ chế Rate Limiting dựa trên địa chỉ IP nguồn (get_remote_address).	Thiết lập các tham số cửa sổ thời gian và ngưỡng giới hạn chặt chẽ nhằm chống lại các cuộc tấn công ngập lụt.
Postman / cURL	Latest	Công cụ kiểm thử thủ công, gửi request HTTP kiểm tra phản hồi endpoint.	Chỉ sử dụng để kiểm tra xác thực endpoint trong quá trình debug và kiểm thử lab.

3.4. Quy trình triển khai/đánh giá

Bước	Công việc	Đầu ra	Minh chứng trong repo	Mốc thời gian
1	Khảo sát tài liệu, nghiên cứu kiến trúc IoT, các chuẩn bảo mật quốc tế (như OWASP ISVS, ISTG) và phân tích sâu cơ chế tấn công DoS tầng ứng dụng.	Báo cáo cơ sở lý thuyết chi tiết, tài liệu tổng quan.	/report/Bao_cao, README.md	Tuần 2
2	Thiết kế kiến trúc hệ thống, xây dựng sơ đồ luồng dữ liệu (DFD), xác định ranh giới tin cậy (Trust Boundary) và phân tích mối đe dọa thông qua khung STRIDE.	Sơ đồ kiến trúc, Bảng phân tích mối đe dọa & ma trận rủi ro (Risk Register).	/report/Bao_cao	Tuần 3
3	Lập trình ứng dụng Flask API Gateway, tích hợp module Flask-Limiter để thiết lập hàng rào giới hạn tần suất dựa trên địa chỉ IP nguồn.	Mã nguồn hoàn chỉnh của API Gateway, tập tin cấu hình hệ thống.	/src/app.py, /configs/config.json	Tuần 3
4	Viết script mô phỏng thiết bị IoT tạo dữ liệu telemetry mẫu và kịch bản tấn công ngập lụt (Flooding) với các mức cường độ khác nhau.	Script kiểm thử tự động, cấu trúc dữ liệu payload mẫu.	/src/flood_test.py, /data/payload_mau.json	Tuần 4
5	Vận hành hệ thống thực nghiệm cục bộ, thực thi 5 kịch bản kiểm thử (từ TC-01 đến TC-05), thu thập nhật ký log hệ thống và hình ảnh minh chứng.	Thư mục nhật ký minh chứng và tệp log thực nghiệm.	/results/screenshots/, /results/logs/syslog.txt	Tuần 4

3.5. Tiêu chí đánh giá

Hệ thống phòng thủ được đánh giá dựa trên các tiêu chí định lượng và ngưỡng đạt cụ thể sau:

- **Xử lý lưu lượng hợp lệ (TC-01):** Đạt tỷ lệ **100%** các request hợp lệ (≤ 1 request/giây) được Gateway tiếp nhận và phản hồi thành công với mã trạng thái HTTP 200 OK.
- **Phát hiện và ngăn chặn DoS (TC-02 & TC-04):** Phát hiện và chặn đứng **100%** các luồng request dồn dập vượt ngưỡng ($> \text{requests}/10\text{s}$), đồng thời trả về mã lỗi chuẩn HTTP 429 Too Many Requests.
- **Độ trễ hệ thống (Latency):** Thời gian phản hồi trung bình của API Gateway duy trì ở mức thấp ($\leq 50\text{ms}$) đảm bảo không gây ảnh hưởng đến hiệu năng của thiết bị biên.
- **Độ chính xác định danh nguồn (TC-05):** Phân tách và áp dụng hạn mức độc lập chính xác 100% theo địa chỉ IP nguồn (`get_remote_address`), cô lập hoàn toàn client vi phạm mà không ảnh hưởng đến các thiết bị khác.
- **Khả năng phục hồi tự động (TC-03):** Hệ thống tự động mở khóa cho IP sau khi hết thời gian cửa sổ (*window time*), cho phép thiết bị tiếp tục gửi dữ liệu và nhận phản hồi 200 OK mà không cần can thiệp thủ công.
- **Mức giảm rủi ro (Risk Reduction):** Khắc phục hoàn toàn các điểm yếu phát hiện (*findings*), giảm mức độ rủi ro đối với tài nguyên xử lý và dịch vụ (ISTG-PROC, ISTG-DES) từ mức Cao (High) xuống mức Thấp / Chấp nhận được (Low / Residual Risk).

CHƯƠNG 4. TRIỂN KHAI VÀ KẾT QUẢ

4.1. Chuẩn bị môi trường

Để tái hiện và triển khai hệ thống thực nghiệm phòng thủ DoS tại API Gateway, môi trường phần mềm được thiết lập cụ thể như sau:

- **Hệ điều hành:** Windows 10/11 hoặc Linux (Ubuntu 20.04+).
- **Ngôn ngữ lập trình:** Python phiên bản 3.10 trở lên.
- **Môi trường ảo (Virtual Environment):** Sử dụng venv để cách ly các thư viện phụ thuộc của đồ án.
- **Thư viện mã nguồn mở bắt buộc:**
 - **Flask (Phiên bản 3.1.x):** Xây dựng API Gateway nhận dữ liệu telemetry.
 - **Flask-Limiter (Phiên bản 3.x):** Thư viện chuyên dụng tích hợp cơ chế Rate Limiting dựa trên địa chỉ IP nguồn của client.

```
Microsoft Windows [Version 10.0.19045.6466]
(c) Microsoft Corporation. All rights reserved.

C:\Users\ADMIN> venv\Scripts\activate.bat

(venv) C:\Users\ADMIN> CD\
(venv) C:\>python \src\app.py
C:\Users\ADMIN\venv\Lib\site-packages\flask_limiter\extension.py:364: UserWarning: Using the in-memory storage for tracking rate limits as no storage was explicitly specified. This is not recommended for production use. See: https://flask-limiter.readthedocs.io#configuring-a-storage-backend for documentation about configuring the storage backend.
  warnings.warn(
* Serving Flask app 'app'
* Debug mode: on
WARNING: This is a development server. Do not use it in a production deployment. Use a production WSGI server instead.
* Running on http://127.0.0.1:5000
Press CTRL+C to quit
* Restarting with stat
C:\Users\ADMIN\venv\Lib\site-packages\flask_limiter\extension.py:364: UserWarning: Using the in-memory storage for tracking rate limits as no storage was explicitly specified. This is not recommended for production use. See: https://flask-limiter.readthedocs.io#configuring-a-storage-backend for documentation about configuring the storage backend.
  warnings.warn(
* Debugger is active!
* Debugger PIN: 618-593-567
```

Hình 4.1. Giao diện Terminal khởi chạy thành công môi trường ảo venv và Flask API Gateway trên cổng 5000

4.2. Thành phần sản phẩm

STT	Thành phần	Đường dẫn repo	Chức năng	Người thực hiện
1	Sơ đồ kiến trúc / DFD	report/Baocao/	Mô tả hệ thống và ranh giới tin cậy	Trịnh Minh Hoàng Bảo
2	Risk Register	report/Baocao/	Quản lý rủi ro và nhận diện mối đe dọa	Trịnh Minh Hoàng Bảo

STT	Thành phần	Đường dẫn repo	Chức năng	Người thực hiện
3	Ma trận rủi ro 5×5	report/Baocao/	Đánh giá xác suất và ảnh hưởng rủi ro Trịnh Minh Hoàng Bảo	
4	Kế hoạch xử lý	report/Baocao/	Đề xuất biện pháp giảm thiểu DoS	Trịnh Minh Hoàng Bảo
5	Checklist bảo mật	report/Baocao/	Kiểm tra định kỳ an ninh hệ thống	Trịnh Minh Hoàng Bảo
6	Tài liệu hướng dẫn	README.md	Hướng dẫn thiết lập và chạy lab	Trịnh Minh Hoàng Bảo

Ngoài các sản phẩm phân tích ở trên, repo còn có ba thư mục hỗ trợ minh chứng kỹ thuật: configs/ chứa cấu hình mô phỏng dùng làm bằng chứng lỗ hổng và biện pháp khắc phục (config.json – danh mục tham số Rate Limiting hệ thống); data/ chứa dữ liệu mẫu minh họa payload (payload_mau.json – cấu trúc thông số nhiệt độ, độ ẩm từ thiết bị biên); src/ chứa mã nguồn API Gateway (app.py) và script kiểm thử ngập lụt (flood_test.py) dùng để tái tạo kết quả thực nghiệm tại mục 4.4.

4.3. Kịch bản thử nghiệm/áp dụng

ID	Mục tiêu	Đầu vào	Thao tác	Kết quả mong đợi	Minh chứng
TC-01	Kiểm tra xử lý lưu lượng hợp lệ	Payload JSON mẫu từ thiết bị (/src/flood_test.py)	Gửi request với nhịp độ thấp (\$\le 1\$ req/s) từ client hợp lệ.	Gateway tiếp nhận, xử lý thành công và phản hồi mã trạng thái 200 OK.	Ảnh chụp log terminal hiển thị 200 OK (/results/logs/).
TC-02	Kiểm tra cơ chế chống tấn công DoS (Flooding)	Payload JSON gửi dồn dập liên tục	Kích hoạt script phóng lượng lớn request vượt ngưỡng cho phép (\$>5\$ req/10s).	Kích hoạt Rate Limiting, chặn đứng và trả về 429 Too Many Requests.	Ảnh log hiển thị cảnh báo và lỗi 429 (/results/screenshots/).
TC-03	Kiểm tra tính phục hồi sau khi bị khóa	IP bị giới hạn do vượt ngưỡng	Tạm ngưng gửi request trong khoảng thời gian cửa sổ, sau đó gửi lại request mới.	Hệ thống tự động mở khóa, cho phép thiết bị tiếp tục gửi dữ liệu và nhận phản hồi 200 OK.	Phản hồi quay về trạng thái thành công (/results/logs/).
TC-04	Kiểm tra định dạng phản hồi lỗi chuẩn	Request bị từ chối từ IP quá tải	Truy cập endpoint khi đang bị khóa hệ thống.	Trả về cấu trúc JSON thông báo lỗi tiêu chuẩn (Too Many Requests).	Payload JSON lỗi trả về từ API (/results/screenshots/).

ID	Mục tiêu	Đầu vào	Thao tác	Kết quả mong đợi	Minh chứng
TC-05	Kiểm tra tính cô lập giữa các nguồn client	Các request gửi từ các địa chỉ IP hoặc phiên giả lập khác nhau	Mô phỏng nhiều nguồn client gửi dữ liệu đồng thời.	Client vi phạm bị chặn, các client gửi đúng chuẩn tiếp tục được phục vụ bình thường.	Nhật ký hệ thống phân tách theo IP (/results/logs/).

4.4. Kết quả

Kết quả xử lý lưu lượng hợp lệ (Kịch bản TC-01): Khi thiết bị IoT gửi dữ liệu với nhịp độ ổn định (≤ 1 request/giây), API Gateway xử lý mượt mà và trả về 200 OK.

Kết quả phát hiện và ngăn chặn tấn công DoS (Kịch bản TC-02 & TC-04): Khi script kích hoạt tấn công ngập lụt dồn dập vượt ngưỡng, hệ thống lập tức ghi nhận cảnh báo trên console: [!] Cảnh báo: Phát hiện lưu lượng vượt ngưỡng từ IP 127.0.0.1 (Dấu hiệu DoS/Flooding) và trả về mã lỗi chuẩn 429 Too Many Requests.

Kết quả phân tách định danh nguồn (Kịch bản TC-05): Hệ thống theo dõi bộ đếm độc lập dựa trên hàm get_remote_address, đảm bảo không ảnh hưởng các client hợp lệ khác.

Bảng đối chiếu kết quả thực tế với tiêu chí đánh giá (Mục 3.5):

Tiêu chí đánh giá	Ngưỡng đạt yêu cầu	Kết quả thực tế	Trạng thái đối chiếu	Minh chứng
Xử lý hợp lệ (TC-01)	100% request ≤ 1 /s đạt 200 OK	Đạt 100% các request hợp lệ trả về thành công	Đạt	/results/logs/
Ngăn chặn DoS (TC-02)	100% request vượt ngưỡng bị chặn	Chặn đứng toàn bộ luồng dồn dập, trả về 429	Đạt	/results/screenshots/
Độ trễ hệ thống (Latency)	≤ 50 ms trung bình	Duy trì độ trễ xử lý thấp, không gây nghẽn	Đạt	Đo lường thực tế
Độ chính xác định danh (TC-05)	100% cô lập đúng IP vi phạm	Phân tách độc lập chính xác qua IP nguồn	Đạt	File log hệ thống
Khả năng phục hồi (TC-03)	Tự động mở khóa sau cửa sổ thời gian	Tự động khôi phục trạng thái sau khi hết thời gian chờ	Đạt	Kịch bản TC-03

4.5. Script sinh báo cáo

Cách chạy: Mở terminal tại thư mục gốc, kích hoạt môi trường ảo và thực thi lệnh:

- `python src/flood_test.py`

Input: Tập dữ liệu payload mẫu từ `/data/payload_mau.json` và cấu hình ngưỡng.

Output: Sinh ra các chuỗi request mô phỏng và ghi log trực tiếp vào tệp nhật ký `/results/logs/syslog.txt`.

--- [TC-01] Kiểm tra lưu lượng hợp lệ (Nhịp độ chậm) ---

Request 1: Status Code = 200 | Phản hồi: {'message': 'Đã tiếp nhận dữ liệu cảm biến thành công.', 'status': 'success'}

Request 2: Status Code = 200 | Phản hồi: {'message': 'Đã tiếp nhận dữ liệu cảm biến thành công.', 'status': 'success'}

--- [TC-02] Mô phỏng tấn công ngập lụt (Gửi dồn dập vượt ngưỡng 5 lần/10s) ---

Flood Request 1: Status Code = 200 | Phản hồi: {'message': 'Đã tiếp nhận dữ liệu cảm biến thành công.', 'status': 'success'}

Flood Request 2: Status Code = 200 | Phản hồi: {'message': 'Đã tiếp nhận dữ liệu cảm biến thành công.', 'status': 'success'}

Flood Request 3: Status Code = 200 | Phản hồi: {'message': 'Đã tiếp nhận dữ liệu cảm biến thành công.', 'status': 'success'}

Flood Request 4: Status Code = 429 | Phản hồi: {'error': 'Too Many Requests', 'message': 'Vượt quá giới hạn cho phép. Yêu cầu đã bị từ chối để bảo vệ hệ thống.'}

Flood Request 5: Status Code = 429 | Phản hồi: {'error': 'Too Many Requests', 'message': 'Vượt quá giới hạn cho phép. Yêu cầu đã bị từ chối để bảo vệ hệ thống.'}

Flood Request 6: Status Code = 429 | Phản hồi: {'error': 'Too Many Requests', 'message': 'Vượt quá giới hạn cho phép. Yêu cầu đã bị từ chối để bảo vệ hệ thống.'}

Flood Request 7: Status Code = 429 | Phản hồi: {'error': 'Too Many Requests', 'message': 'Vượt quá giới hạn cho phép. Yêu cầu đã bị từ chối để bảo vệ hệ thống.'}

Bảng tổng hợp kết quả

Tiêu chí (mục tiêu)	Kỳ vọng	Kết quả thực tế	Đạt/Chưa đạt	Minh chứng
Xử lý lưu lượng hợp lệ (TC-01)	Phản hồi nhanh chóng, không có độ trễ lớn với nhịp độ thấp ($\leq 1\text{req/s}$).	Các request đầu tiên trả về 200 OK kèm JSON thành công.	Đạt	File log <code>/results/logs/</code>

Phát hiện tấn công DoS (TC-02)	Nhận diện kịp thời các luồng request dồn dập vượt ngưỡng cấu hình.	Hệ thống ghi nhận cảnh báo phát hiện lưu lượng vượt ngưỡng từ IP.	Đạt	File log /results/screenshots/
Ngăn chặn quá tải / HTTP 429 (TC-04)	Từ chối các request quá tải, bảo vệ tài nguyên backend (CPU/RAM).	Chặn và trả về mã lỗi chuẩn 429 Too Many Requests.	Đạt	Payload JSON lỗi /results/screenshots/
Phân tách định danh nguồn (TC-05)	Theo dõi và áp dụng hạn mức độc lập theo từng địa chỉ IP.	Ghi nhận log phân tách rõ ràng theo nguồn IP của client (127.0.0.1).	Đạt	File log hệ thống
Khả năng phục hồi tự động (TC-03)	Tự động mở khóa sau khi hết thời gian cửa sổ chờ.	Khôi phục trạng thái nhận request hợp lệ (200 OK) sau khi ngưng gửi dồn dập.	Đạt	Kịch bản TC-03

4.6. Thảo luận và hạn chế

4.6.1. Đối chiếu kết quả với mục tiêu

Kết quả thực nghiệm đã minh chứng thành công các mục tiêu cốt lõi của đề tài: xây dựng thành công mô hình API Gateway trọng lượng nhẹ bằng Flask, tích hợp hiệu quả cơ chế Rate Limiting để vô hiệu hóa các kịch bản tấn công ngập lụt tầng ứng dụng (HTTP Flood). Hệ thống đảm bảo phân định rõ ràng giữa lưu lượng hợp lệ (200 OK) và lưu lượng quá tải (429 Too Many Requests), bảo vệ tuyệt đối năng lực xử lý của hạ tầng backend.

4.6.2. Hạn chế

Môi trường mô phỏng cục bộ: Mô hình mới chỉ được kiểm chứng trong môi trường mạng nội bộ (Localhost) trên cùng một máy cá nhân, chưa thử nghiệm trên các điều kiện mạng diện rộng (WAN) có độ trễ lớn.

Cơ chế lưu trữ trạng thái (In-memory storage): Đồ án hiện tại sử dụng bộ nhớ RAM tạm thời của thư viện Flask-Limiter để đếm số lượng request, chưa áp dụng cơ chế lưu trữ phân tán (như Redis) phục vụ cho hệ thống cụm Server quy mô lớn.

Phạm vi mô phỏng tấn công: Đồ án tập trung giải quyết bài toán tấn công lũ lụt ở tầng ứng dụng (HTTP Flood), chưa bao quát các hình thức tấn công từ chối dịch vụ ở tầng mạng (SYN Flood, UDP Flood).

CHƯƠNG 5. ĐÁNH GIÁ BẢO MẬT

5.1. Tài sản và dữ liệu

Bảng 5.1 liệt kê các tài sản cốt lõi của hệ thống IoT và yêu cầu bảo mật theo tam giác CIA (Confidentiality, Integrity, Availability):

Tài sản/dữ liệu	Chủ thể	Mức quan trọng	Yêu cầu C-I-A	Ghi chú
Dữ liệu Telemetry (JSON)	Thiết bị biên / Cảm biến	Trung bình	C: Thấp I: Cao A: Trung bình	Đảm bảo dữ liệu thông số nhiệt độ, độ ẩm không bị chỉnh sửa trên đường truyền.
API Gateway Server	Máy chủ trung chuyển	Cao	C: Trung bình I: Cao A: Cao	Điểm nút tiếp nhận toàn bộ lưu lượng dữ liệu từ thiết bị IoT.
Tài nguyên phần cứng (CPU/RAM)	Hệ thống hạ tầng	Cao	C: Thấp I: Thấp A: Cao	Tránh bị cạn kiệt tài nguyên khi chịu các cuộc tấn công ngập lụt.
Kênh truyền thông HTTP/RESTful	Mạng giao tiếp	Trung bình	C: Trung bình I: Trung bình A: Cao	Bảo vệ gói tin truyền tải giữa thiết bị biên và máy chủ Gateway.
Dữ liệu Telemetry (JSON)	Thiết bị biên / Cảm biến	Trung bình	C: Thấp I: Cao A: Trung bình	Đảm bảo dữ liệu thông số nhiệt độ, độ ẩm không bị chỉnh sửa trên đường truyền.
API Gateway Server	Máy chủ trung chuyển	Cao	C: Trung bình I: Cao A: Cao	Điểm nút tiếp nhận toàn bộ lưu lượng dữ liệu từ thiết bị IoT.

Bảng 5.1. Tài sản và dữ liệu cần bảo vệ

5.2. Mối đe dọa và lỗ hổng

Ánh xạ khung mô hình hóa mối đe dọa STRIDE và OWASP IoT Top 10 vào hệ thống:

ID	Tài sản	Mối đe dọa	Lỗ hổng	Tác động	Minh chứng/nguồn
TH-01	API Gateway / Tài nguyên CPU & RAM	Tấn công ngập lụt từ chối dịch vụ (HTTP Flood / DoS)	Endpoint API mở công khai nhưng thiếu cơ chế Rate Limiting tự động giới hạn tần suất.	Cao (Làm tê liệt dịch vụ, cạn kiệt tài nguyên xử lý)	Script kiểm thử (/src/flood_test.py), file log (/results/logs/)
TH-02	Dữ liệu Telemetry & Thiết bị biên	Giả mạo thiết bị (Spoofing)	Thiếu cơ chế xác thực mạnh (Token/Certificate) cho các thiết bị kết nối vào Gateway.	Trung bình (Dữ liệu rác làm sai lệch hệ thống giám sát)	Sơ đồ luồng dữ liệu (DFD), OWASP IoT Top 10
TH-03	Kênh truyền thông HTTP/RESTful	Nghe lén / Sửa đổi dữ liệu (Tampering / Disclosure)	Sử dụng giao thức HTTP thuần túy không mã hóa kênh truyền.	Trung bình (Lộ thông tin thông số môi trường hoặc bị can thiệp gói tin)	Báo cáo cơ sở lý thuyết OWASP ISVS/ISTG

Bảng 5.2. Mối đe dọa và lỗ hổng

5.3. Ma trận rủi ro

Ma trận đánh giá rủi ro 5×5 (Khả năng xuất hiện $\times$ Mức độ tác động) trước và sau khi áp dụng biện pháp phòng thủ:

ID	Khả năng (1-5)	Tác động (1-5)	Điểm m	Mức rủi ro	Biện pháp	Rủi ro còn lại
R1	4	5	20	Cao (High)	Tích hợp cơ chế Rate Limiting dựa trên IP (Flask-Limiter) tại API Gateway.	Tấn công phân tán từ mạng lưới nhiều địa chỉ IP (Botnet DDoS).
R2	3	3	9	Trung bình (Medium)	Sử dụng mã xác thực API Token / mTLS cho thiết bị biên kết nối.	Lộ khóa bí mật (API Key/Token) từ phía thiết bị biên.
R3	2	3	6	Thấp (Low)	Bắt buộc sử dụng giao thức truyền thông mã hóa HTTPS (TLS).	Cấu hình sai chứng chỉ SSL/TLS hoặc lỗi từ phía chứng chỉ tự ký.

Bảng 5.3. Ma trận rủi ro

5.4. Biện pháp giảm thiểu

Đối với rủi ro trọng tâm (R1 - Tấn công DoS): Triển khai giải pháp Rate Limiting dựa trên địa chỉ IP nguồn (`get_remote_address`) tại tầng API Gateway thông qua thư viện Flask-Limiter. Giải pháp này giúp tự động sàng lọc lưu lượng, chặn đứng các yêu cầu vượt ngưỡng và phản hồi mã lỗi chuẩn HTTP 429 Too Many Requests.

Phân biệt bảo vệ kênh và bảo vệ đầu-cuối:

- Bảo vệ kênh (Channel Protection): Sử dụng giao thức HTTPS (TLS) để đảm bảo tính bí mật và toàn vẹn dữ liệu khi truyền tải qua mạng.
- Bảo vệ đầu-cuối (End-to-End Protection): Áp dụng cơ chế xác thực định danh thiết bị (Token/API Key) và kiểm soát hạn mức (Rate Limiting) ngay tại điểm cuối (Gateway).

5.5. Rủi ro còn lại

Sau khi triển khai cơ chế Rate Limiting, rủi ro cạn kiệt tài nguyên do HTTP Flood từ một địa chỉ IP đơn lẻ đã được giảm từ mức Cao xuống mức Thấp (Chấp nhận được).

Điều kiện cần xem xét lại: Nếu kẻ tấn công sử dụng mạng lưới thiết bị phân tán (DDoS từ hàng nghìn địa chỉ IP botnet khác nhau), cơ chế Rate Limiting dựa trên IP đơn lẻ có thể bị vô hiệu hóa. Khi đó, hệ thống cần được nâng cấp các giải pháp phòng thủ nâng cao như tích hợp WAF hoặc chuyển đổi sang cấu trúc lưu trữ phân tán (Redis).

CHƯƠNG 6. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

6.1. Kết luận

Đồ án đã hoàn thành xuất sắc các mục tiêu nghiên cứu đề ra thông qua việc vận dụng chặt chẽ khung phân tích kỹ thuật và giải pháp phòng thủ:

- MT-01 (Xác định và phân loại tài sản): Đã hoàn thành, làm rõ danh mục tài sản hệ thống và ranh giới tin cậy tại Chương 1 và Chương 3.
- MT-02 (Phân tích mối đe dọa và lỗ hổng): Đã hoàn thành, xây dựng thành công bảng phân tích và ánh xạ lỗ hổng tại Chương 3 và Chương 5.
- MT-03 (Xây dựng Risk Register): Đã hoàn thành, thiết lập ma trận đánh giá rủi ro và bảng ưu tiên xử lý tại Chương 3 và Chương 5.
- MT-04 (Đề xuất biện pháp giảm thiểu): Đã hoàn thành, triển khai thành công mô hình API Gateway tích hợp Rate Limiting và kiểm chứng qua thực nghiệm tại Chương 4 và Chương 5.
- MT-05 (Xây dựng Checklist kiểm tra bảo mật): Đã hoàn thành, thiết lập bộ checklist an ninh định kỳ dựa trên tiêu chuẩn OWASP ISVS/ISTG tại Chương 6.

6.2. Hạn chế

Mô hình mới chỉ dừng lại ở phạm vi mô phỏng cục bộ (Localhost), chưa kiểm chứng trên thiết bị phần cứng IoT thực tế.

Chưa tích hợp cơ chế lưu trữ phân tán (Redis) cho hệ thống giới hạn tần suất quy mô lớn.

Phạm vi tấn công giới hạn ở tầng ứng dụng (HTTP Flood).

6.3. Hướng phát triển

1. Triển khai trên thiết bị thật: Đưa mã nguồn script mô phỏng lên các vi điều khiển thực tế (như ESP32 hoặc Wokwi simulator).
2. Nâng cấp bảo mật kênh truyền: Triển khai chứng chỉ số SSL/TLS và giao thức bảo mật mTLS.
3. Xây dựng Dashboard trực quan: Tích hợp giao diện giám sát lưu lượng thời gian thực (Grafana / Prometheus).
4. Mở rộng quy mô Dataset và cơ chế phân tán: Tích hợp Redis backend cho Flask-Limiter.

TÀI LIỆU THAM KHẢO

- [1] OWASP Foundation — OWASP Internet of Things Security Verification Standard (ISVS) — <https://github.com/OWASP/IoT-Security-Verification-Standard-ISVS> — Truy cập ngày 17/07/2026 — Dùng cho Chương 2, 3 và 6 (Khung tiêu chuẩn xác thực an ninh IoT).
- [2] OWASP Foundation — OWASP IoT Security Testing Guide (ISTG) — <https://github.com/OWASP/owasp-istg> — Truy cập ngày 17/07/2026 — Dùng cho Chương 3 và 5 (Phương pháp luận kiểm thử xâm nhập tài nguyên).
- [3] Pallets Projects — Flask Documentation & Repository — <https://github.com/pallets/flask> — Truy cập ngày 17/07/2026 — Dùng cho Chương 3 và 4 (Xây dựng API Gateway).
- [4] OWASP Foundation — OWASP Top 10 Internet of Things — <https://owasp.org/www-project-internet-of-things/> — Truy cập ngày 17/07/2026 — Dùng cho Chương 2 và 5 (Tham chiếu các nguy cơ bảo mật phổ biến).
- [5] International Organization for Standardization — ISO/IEC 27400:2022 - Cybersecurity — IoT — Guidelines for risk management — (Tài liệu tiêu chuẩn quốc tế) — Truy cập ngày 17/07/2026 — Dùng cho Chương 3 và 5 (Nguyên tắc kiểm soát rủi ro IoT).
- [6] Trịnh Minh Hoàng Bảo. Tấn công từ chối dịch vụ và giảm thiểu (Mã nguồn đề tài). <https://github.com/SSAbys/Nhom25-iot-dos-mitigation>. Nhánh main. Truy cập ngày 26/07/2026.

PHỤ LỤC A. CẤU TRÚC REPO VÀ GÓI NỘP

Repo GitHub cá nhân: <https://github.com/SSAbys/Nhom25-iot-dos-migitation>

iot-gateway-dos-defense/

- |— README.md
- |— report/
 - | — Baocao/
 - | | — TieuLuan_CuoiKy.docx
 - | | — TieuLuan_CuoiKy.pdf
- |— slides/
 - | | — SlideTrinhBay.pptx
 - | | — SlideTrinhBay.pdf
- |— results/
 - | | — screenshots/
 - | | | — Demo.PNG
 - | | | — SoDoCauTruc.png
 - | | — logs/
 - | | | — syslogs.txt
 - | | — TC-01.PNG
 - | | — TC-02-Client.PNG
 - | | — TC-02-Server.PNG
 - | | — TC-04.PNG
 - | | — TC-05.PNG
- |— src/
 - | | — app.py
 - | | — flood_test.py
- |— data/
 - | | — payload_mau.json
- |— configs/
 - | | — config.json
- |— references/
 - | | — link_nguon.md

Bảng A.1 dưới đây dùng để ghi lại nhật ký các lần chạy script/công cụ hỗ trợ thực nghiệm phòng thủ DoS tại API Gateway (ví dụ: script mô phỏng tấn công, kiểm tra Rate Limiting).

STT	Ngày chạy	Script/công cụ	Mục đích	Kết quả tóm tắt / File log
VD	dd/mm/2026	(tên script/công cụ nhóm dùng)	Tổng hợp/kiểm tra dữ liệu Risk Register	logs/run_dd-mm.log
1	24/07/2026	src/flood_test.py	Mô phỏng lưu lượng chuẩn (TC-01) và tấn công ngập lụt (TC-02/TC-04)	Phản hồi 200 OK và 429 Too Many Requests; results/logs/syslog.txt

Bảng A.1. Nhật ký chạy script/công cụ (script log)

PHỤ LỤC B. NHẬT KÝ ĐÓNG GÓP

ST T	Họ tên - MSSV	Công việc	Commit/file	Tỷ lệ (%)	Xác nhận
1	Trịnh Minh Hoàng Bảo – 231A010432	Toàn bộ nội dung: xây dựng API Gateway, tích hợp Flask-Limiter, viết script mô phỏng flood_test, lập Risk Register, ma trận rủi ro, checklist và báo cáo	src/, configs/, data/, results/, report/	100%	☒

PHỤ LỤC C. CHECKLIST TRƯỚC KHI NỘP

ST T	Nội dung kiểm tra	Trạng thái
1	Báo cáo đủ các phần chính, mục lục và tài liệu tham khảo.	☒ Đạt ☐ Chưa đạt
2	Độ dài báo cáo chính 10-15 trang, không tính phụ lục.	☒ Đạt ☐ Chưa đạt
3	Repo mở được; README có cách chạy/sử dụng và mô tả cấu trúc.	☒ Đạt ☐ Chưa đạt
4	Có sản phẩm kỹ thuật hoặc sản phẩm phân tích hoàn chỉnh.	☒ Đạt ☐ Chưa đạt
5	Có ít nhất 3 minh chứng kiểm tra được trong results/ hoặc báo cáo.	☒ Đạt ☐ Chưa đạt
6	Có ít nhất 5 tài liệu tham khảo và repo GitHub/tool chính.	☒ Đạt ☐ Chưa đạt
7	Mọi hình/bảng có tên, số thứ tự, nguồn và phần phân tích.	☒ Đạt ☐ Chưa đạt
8	Không có secret, token, mật khẩu, dữ liệu cá nhân hoặc file nhạy cảm.	☒ Đạt ☐ Chưa đạt
9	Mọi thử nghiệm chỉ diễn ra trong môi trường local/được phép.	☒ Đạt ☐ Chưa đạt

10	Slide có 8-12 trang, link repo, kết quả chính, rủi ro và kết luận.	☐ Đạt ☒ Chưa đạt
11	Đã cập nhật mục lục, kiểm tra chính tả và xóa toàn bộ hướng dẫn mẫu.	☒ Đạt ☐ Chưa đạt

PHỤ LỤC D. PHIẾU TỰ ĐÁNH GIÁ THEO RUBRIC

Tiêu chí	Điểm tối đa	Tự chấm	Minh chứng/ghi chú
Đúng đề tài, đúng phạm vi	1,0	1,0	Đúng đề tài phòng thủ DoS tại API Gateway. Phạm vi, đối tượng, giới hạn nêu rõ tại mục 1.4.
Nguồn GitHub và tài liệu tham khảo	1,0	1,0	Repo GitHub cá nhân; tài liệu tham khảo đầy đủ URL, ngày truy cập (references/link_nguồn.md).
Cơ sở lý thuyết	1,0	1,0	Kiến trúc IoT, API Gateway, khái niệm Rate Limiting, tiêu chuẩn OWASP ISVS/ISTG.
Cách làm/phương pháp	1,0	1,0	Phương pháp đánh giá rủi ro Asset-Based, quy trình triển khai mô hình Flask và Flask-Limiter.
Sản phẩm kỹ thuật hoặc sản phẩm phân tích	2,0	2,0	API Gateway (src/app.py), Script kiểm thử (src/flood_test.py), Risk Register, Ma trận rủi ro, Checklist.
Phân tích bảo mật/rủi ro/biện pháp	1,5	1,5	Phân tích rủi ro HTTP Flood, áp dụng cơ chế Rate Limiting, ánh xạ OWASP ISVS.
Trình bày, hình bảng và trích dẫn	1,0	1,0	Cấu trúc chương chuẩn, danh mục bảng/hình, trích dẫn tài liệu tham khảo nhất quán.
Slide và bảo vệ	1,0	1,0	Slide trình bày đầy đủ bố cục, link repo, kết quả thực nghiệm và kết luận.

Tiêu chí	Điểm tối đa	Tự chấm	Minh chứng/ghi chú
Tuân thủ an toàn và đạo đức	0,5	0,5	Thử nghiệm nội bộ trên môi trường local, không tấn công hệ thống thực tế, không chứa secret/token.
TỔNG	10,0		